

Controls and compliance checklist

Author: Herbert Muller Wilcke

Org: Botium Toys

Controls assessment checklist

Yes	No	Control
☐	☒	Least Privilege
☐	☒	Disaster recovery plans
☒	☐	Password policies
☐	☐	Separation of duties
☒	☐	Firewall
☐	☒	Intrusion detection system (IDS)
☐	☒	Backups
☒	☐	Antivirus software
☒	☒	Manual monitoring, maintenance, and intervention for legacy systems
☐	☒	Encryption
☐	☒	Password management system
☒	☐	Locks (offices, storefront, warehouse)
☒	☐	Closed-circuit television (CCTV) surveillance
☒	☐	Fire detection/prevention (fire alarm, sprinkler system, etc.)

Does Botium Toys currently have this control in place?

Botium Toys currently does not have the site under control. This is due to the fact that they did not apply an ideal security policy (CIS benchmark hardening or some other framework). In this case, there is no type of incident response or recovery method, making it impossible to properly follow the NIST CSF framework. Since there is no least privilege implemented, permissions are misconfigured and authenticity often cannot be validated, possibly resulting in insider damage or accidental employee actions. Finally, the policy must be improved because the CIA triad is being violated in all aspects.

Does Botium Toys currently adhere to this compliance best practice?

Botium Toys does not currently adhere to compliance best practices regarding control categories. This can be concluded due to the lack of incident response protocols, nonexistent backups, and poor management practices. These are critical aspects that help maintain the company's integrity and significantly improve its overall security posture.

Compliance checklist**Payment Card Industry Data Security Standard (PCI DSS)**

Yes	No	Best practice
☐	☒	Only authorized users have access to customers' credit card information.
☐	☒	Credit card information is stored, accepted, processed, and transmitted internally, in a secure environment.
☐	☒	Implement data encryption procedures to better secure credit card transaction touchpoints and data.
☐	☒	Adopt secure password management policies.

General Data Protection Regulation (GDPR)

Yes	No	Best practice
☐	☒	E.U. customers' data is kept private/secured.
☒	☐	There is a plan in place to notify E.U. customers within 72 hours if their data is compromised/there is a breach.
☐	☒	Ensure data is properly classified and inventoried.
☐	☒	Enforce privacy policies, procedures, and processes to properly document and maintain data.

System and Organizations Controls (SOC type 1, SOC type 2)

Yes	No	Best practice
☐	☒	User access policies are established.
☐	☒	Sensitive data (PII/SPII) is confidential/private.
☒	☐	Data integrity ensures the data is consistent, complete, accurate, and has been validated.
☒	☐	Data is available to individuals authorized to access it.

Recommendations (optional): In this section, provide recommendations, related to controls and/or compliance needs, that your IT manager could communicate to stakeholders to reduce risks to assets and improve Botium Toys' security posture.

Least Privilege: This is absolutely necessary in order to maintain control over user authentication and ensure better management of system users (employees, managers, administrators).

Backups: Weekly backups should be implemented to maintain a recovery plan in the event of attacks. These backups should be isolated from the network and inaccessible through login.

Incident Response: Incident response policies should be implemented with a structured playbook guide. Frameworks such as the NIST CSF could be applied, since without backups, recovery would be impossible.

Password Policy Management: Annual password change checks should be enforced, and compliance with password policies must be mandatory. Suspicious login attempts should be automatically flagged in order to prevent damage in the event of incidents, brute force attacks, or dictionary attacks.

PCI: From a legal standpoint, it is absolutely necessary that cardholder information (SPII) be hashed (encrypted) to maintain its security. Previously, all employees were able to view this information. Once these are applied, the data will become unreadable even to “authorized” personnel, thus maintaining security and allowing the company to operate legally (PCI DSS).

GDPR: We must remember that EU users are protected by strict regulations regarding personal data protection. It is essential to store their data separately from regular users’ data so that, in the event of an intrusion, accessing this information would not be as easy (defense in depth).

System Organization: policy audits should be conducted, including analyses performed by the SOC team. Policies should cover user access management, sensitive data and phishing awareness training.

Phishing: Apply MFA to validate the person and avoid incident on successful phishing attacks.